

CYBERSECURITY CASE EXAM PLAYBOOK

Managing Cybersecurity Risks in the Information Age

MBA Year II | Final Term | Open-Internet Case Analysis

PURPOSE: WHAT THIS PDF IS FOR

Use it when the exam gives you an unfamiliar breach or cyber-risk scenario. It tells you what issues to spot, which class frameworks to apply, what controls to recommend, what evidence to Google, and how to turn that into a high-impact ~1000-word mini research report.

Built from: current course outline + professor decks + 6 HBS cases + AY 2024-25 & AY 2025-26 final papers + exam instructions

Current external quick-reference sources verified in September 2026 are clearly labeled as EXTERNAL 2026.

Rule of thumb: Diagnose before you prescribe. Tie every control to a specific weakness and every weakness to business impact.

1. How to Use This Playbook in the Exam

WHY THIS FORMAT: THE EXAMINER'S EXPECTATION

The faculty instructions explicitly encourage a mini research report, trustworthy Internet references, basic citations, diagrams/figures, and roughly 1000 words per question. The current course outline allocates the final exam to CLO 2 and CLO 3: planning/implementing/maintaining security and evaluating real incidents to identify mistakes and lessons.

Recommended time budget for a 20-mark question

Stage	Minutes	Output
Decode the question	4-5	Underline every sub-question; classify the scenario; list 5-8 issue keywords.
Research	8-10	Collect 3-5 strong facts: incident/root cause, technical advisory, framework/regulatory point.
Structure	2-3	Create headings before writing. Choose one diagram/table.
Write	32-35	Diagnosis -> impact -> controls -> governance -> conclusion.
Polish	3-5	Check citations, answer every verb, label the visual, tighten recommendations.

Your default sequence

CASE FACTS -> ASSET -> THREAT ACTOR/MOTIVE -> ATTACK VECTOR -> VULNERABILITY -> CIA IMPACT -> BUSINESS IMPACT -> ROOT CAUSES -> PREVENT/DETECT/RESPOND/RECOVER -> GOVERNANCE/LEGAL -> LESSONS

EXAM MOVE: DO NOT START WITH GENERIC THEORY

Start with a 2-4 sentence interpretation of the incident. Theory earns marks when it explains the case, not when it sits separately from the case.

Exam environment reminder from the faculty email

- Internet access is expected, subject to any later change communicated by faculty.
- Use trustworthy sources with basic citations; avoid wholesale copy-paste.
- The email says Google search should be initiated from the Chrome address bar; visiting the Google homepage itself may fail in the lab environment.
- Diagrams, screenshots, figures and graphs are encouraged when they add analytical value.
- The indicative word limit is around 1000 words per question; structure and content matter more than hitting an exact count.

Class source: Exam Instructions.eml; MCRIA26 - CO (new PLOs).1.pdf.

2. Master Issue Navigator - Start Here When You See the Case

Scan the case for trigger words. Use the matching route below. In the PDF viewer, the major sections also appear as headings/bookmarks.

Trigger words	Go to	Section	What to do first
outdated / legacy / unpatched / CVE / unsupported	Vulnerability & patch management	VULN	Asset inventory -> exposure -> prioritisation -> patch/compensating control -> verify.
password / stolen credential / orphaned account / admin / MFA	IAM & privileged access	IAM	Identity lifecycle -> MFA -> RBAC/least privilege -> PAM -> reviews/logging.
phishing / employee clicked / social engineering	Human + IAM controls	DIAGNOSTIC	Initial vector -> human vulnerability -> MFA -> awareness -> email/endpoint detection.
ransomware / encrypted / ransom / operations stopped	Ransomware & resilience	RANSOM	Initial access -> lateral movement -> encryption/exfiltration -> isolation -> backups -> BCP.
Wi-Fi / remote access / VPN / firewall / network	Network security	NETWORK	Trust boundary -> secure connection -> segmentation -> firewall/VPN -> monitoring.
web app / API / injection / broken access / coding flaw	Application security	APPSEC	SSDLC -> threat model -> SAST/DAST -> OWASP -> input/access/logging controls.
third party / vendor / software update / supplier	Supply-chain risk	SUPPLY	Supplier trust -> build/update integrity -> SBOM/signing -> vendor governance -> monitoring.
printer / router / endpoint / unknown device / hardware	Asset lifecycle	ASSET	Inventory -> owner -> classify -> configure -> monitor -> maintain -> securely retire.
logs / alerts / detection failure / dwell time	Detection & monitoring	MONITOR	IDPS/EDR/SIEM -> log protection -> alerting -> response escalation -> metrics.
pipeline / grid / factory / SCADA / ICS / OT	Critical infrastructure	CRITICAL	IT/OT segmentation -> asset visibility -> safe patching -> resilience -> incident response.
customer data / PII / consent / privacy / data leak	Privacy & data protection	PRIVACY	Privacy vs security -> data minimisation -> access/encryption -> privacy by design -> legal.
8-K / disclosure / media / customers / stock price	Crisis response & communications	INCIDENT	Fact uncertainty -> legal counsel -> stakeholders -> disclosure timing -> trust/reputation.
AI / deepfake / automation / ML / zero trust / SBOM	Emerging trends	TRENDS	Threat amplification + defensive use -> governance -> human oversight -> measurable controls.
government / foreign influence / national security / encryption	Geopolitics & privacy-safety	GEO	Stakeholders -> security risk -> rights/privacy -> law -> proportionality -> trade-offs.

EXAM MOVE: IF THE CASE FITS 3 OR 4 ROWS

That is normal. Strong answers are multi-layered. For example, Colonial Pipeline is simultaneously IAM + VPN + ransomware + critical infrastructure + incident response + business continuity.

3. The 20-Mark Mini Research Report Blueprint

A reusable ~1000-word architecture

Section	Approx. words	What the examiner should see
1. Executive interpretation	70-100	Name the core failure and your thesis: the incident was enabled by X, amplified by Y, and should be addressed through Z.
2. Incident/attack map	100-130	Asset, threat actor/motive, entry vector, vulnerability, attack path. Use only facts that are given or reliably sourced.
3. Root-cause analysis	200-240	People + process + technology + governance. Distinguish immediate cause from systemic cause.
4. Impact assessment	120-160	CIA + operations + finance + customers + reputation + legal/societal impact.
5. Recommendations	280-330	Prioritised controls across Prevent, Detect, Respond, Recover; state owner and why each control addresses the root cause.
6. Governance/legal lens	80-120	NIST/ISO/board/IAM/SSDLC/regulatory obligations only where relevant.
7. Conclusion	50-70	2-3 priorities and the management lesson.

A high-impact opening template

"The incident is best understood not as a single technical failure but as a breakdown across [technology/process/people/governance]. The immediate compromise occurred through [vector/vulnerability], but its severity was amplified by [control gap]. Management should therefore prioritise [top 2-3 controls], while strengthening [governance/monitoring/resilience] to prevent recurrence."

Recommendation rule: every control needs a reason

Weak recommendation	High-impact recommendation
"Use MFA."	"Enforce phishing-resistant MFA on remote and privileged access because stolen credentials alone should not be sufficient to establish a trusted session."
"Update software."	"Maintain a risk-based patch programme tied to an authoritative asset inventory; prioritise internet-facing and known-exploited vulnerabilities, test patches, and use compensating controls when immediate patching is unsafe."
"Train employees."	"Run role-based awareness and phishing simulations, provide a simple reporting path, and measure click/report rates so the control is demonstrably improving behaviour."
"Take backups."	"Maintain offline/isolated, encrypted backups and routinely test restoration; recovery objectives should be aligned with business-critical services."

EXAM MOVE: THE CORE SCORING MOVE

Separate the immediate technical cause from systemic management causes. Example: "compromised VPN credentials" is the immediate cause; failure to deprovision a dormant account and enforce MFA are identity-governance failures.

4. Core Diagnostic Engine: Turn Any Story into Cyber-Risk Analysis

4.1 Asset - Threat - Vulnerability - Attack - Risk - Control

Term	Use in an answer	Case prompt
Asset	Something valuable requiring protection: data, systems, credentials, applications, hardware, business process, reputation.	What was valuable and what depended on it?
Threat / threat actor	Potential source of harm; actor may be cybercriminal, insider, hacktivist, state-linked actor, supplier compromise, etc.	Who could cause harm and why?
Vulnerability	Weakness that can be exploited: unpatched software, weak password, poor config, insecure design, excessive privilege.	What made the attack possible?
Attack / exploit	Action that uses a weakness: phishing, malware, credential abuse, injection, supply-chain compromise.	What actually happened?
Risk	Potential adverse consequence from a threat exploiting a vulnerability; consider likelihood and impact.	What loss becomes plausible?
Control / safeguard	Technical, process or people measure that reduces likelihood or impact.	Which specific control breaks the attack path?

Class source: CS26-1_kQ8Kk1bc6P.pdf - key information security concepts.

4.2 CIA - always test all three

Objective	Failure signal	Typical examples / controls
Confidentiality	Unauthorised disclosure or access.	Data theft, credential exposure; encryption, access control, classification.
Integrity	Unauthorised change or loss of trust in correctness.	Altered transactions/config/code; digital signatures, change control, audit logs.
Availability	Systems/data cannot be used when needed.	Ransomware/DDoS/outage; resilience, redundancy, backups, recovery.

EXAM MOVE: RANSOMWARE CAN HIT ALL THREE

Do not write "ransomware = availability only." Modern incidents may involve data theft (confidentiality), encryption/alteration (integrity) and service shutdown (availability).

4.3 Root causes: People - Process - Technology - Governance

Layer	Issue examples	Strong management language
People	phishing, poor password behaviour, insider abuse, weak skills	Human risk requires role-based awareness, accountability and usable controls - not training alone.
Process	poor patching, no deprovisioning, weak change control, untested response	Security failure becomes repeatable when the business process does not reliably produce the intended control outcome.
Technology	legacy systems, insecure configuration, vulnerable app, flat network, absent MFA/logging	Technology controls should be layered so one failure does not produce enterprise-wide compromise.

Layer	Issue examples	Strong management language
Governance	unclear ownership, weak risk appetite, no board oversight, poor vendor governance	Cyber risk must be integrated into enterprise risk management with assigned accountability, metrics and assurance.

4.4 Threat actor and motivation lens

Actor	Likely motive	What it changes in your analysis
Financial cybercriminal / RaaS affiliate	Extortion, fraud, credential/data monetisation	Emphasise identity, ransomware resilience, exfiltration, payment/business continuity decisions.
Nation-state / state-linked	Espionage, strategic access, disruption, influence	Expect persistence, supply-chain/third-party risk, national-security impact, sophisticated tradecraft.
Insider	Financial/ideological motive or negligence	Privilege, segregation of duties, monitoring, joiner-mover-leaver controls.
Hacktivist	Publicity, ideology, disruption	Availability, data leaks, communications/reputation.
Accidental / non-malicious	Error, misconfiguration, operational failure	Controls should include secure defaults, review, change management and training.

5. Universal Control Library - Prevent, Detect, Respond, Recover

Use this section to avoid generic recommendations. Select only controls that match the case evidence and prioritise them.

Phase	Purpose	Examples you can deploy
PREVENT	Reduce chance of successful compromise.	Asset inventory; secure configuration; patching; MFA; RBAC/least privilege; PAM; segmentation; SSDLC; supplier due diligence; encryption; awareness.
DETECT	Identify suspicious or failed controls quickly.	IDPS; EDR; SIEM/centralised logs; behaviour analytics; vulnerability scanning; alerting; anomaly detection; audit trails.
RESPOND	Contain damage and coordinate decisions.	Incident commander; isolate accounts/endpoints/segments; forensics; legal counsel; regulator/customer communication; preserve evidence.
RECOVER	Restore services and reduce recurrence.	Offline/isolated backups; tested restore; DR/BCP; rebuild from trusted images; lessons learned; control remediation; assurance testing.

Prioritisation language

- Immediate (0-24 hours): contain the active threat, revoke compromised credentials, isolate affected systems, preserve logs/evidence, establish incident command.
- Near term (days-weeks): close root-cause gaps - patch, MFA, deprovisioning, segmentation, monitoring, supplier controls, recovery validation.
- Medium term (weeks-months): governance, architecture, secure development, workforce, metrics, assurance and third-party risk improvements.

EXAM MOVE: BALANCE SECURITY AND AVAILABILITY

The professor's foundation material stresses that security is a process and must balance protection with reasonable access/availability. In critical operations, recommend compensating controls and planned maintenance instead of pretending every system can be patched instantly.

6. Governance, Security Models and ISO - The MBA Layer

6.1 Professor governance model: six steps

Step	What it means	How to use it in a case
1. Build a culture of cyber resilience	Board-led awareness, accountability, strategy, policies and standards.	If users ignored security or leadership treated cyber as IT-only.
2. Establish roles and responsibilities	Board, executive management, CISO/ISM; use RASCI.	If ownership, escalation or decision rights were unclear.
3. Holistic risk management	Integrate cyber risk into enterprise risk; identify threats/vulnerabilities; risk register and tolerance.	If vulnerabilities existed but were not prioritised or accepted explicitly.
4. Cybersecurity collaboration	Steering committee and working groups across business functions.	If technical, legal, operations and communications were disconnected.
5. Create a security programme	Translate strategy into architecture, roadmap, initiatives and continuous improvement.	If the response is a list of tools with no programme/sequence.
6. Measure resilience	Metrics, indicators, assurance, audits, penetration/red-team reports and dashboards.	If management cannot prove controls work.

Class source: 202506-Cyber-Security-Governance-for-session-10.pptx.

6.2 RASCI

Responsible = performs the work; Accountable = owns the outcome; Supporting = helps execute; Consulted = gives input; Informed = kept aware. Use RASCI when a case shows unclear ownership between board, CISO, IT, business, legal or vendors.

6.3 ISO 27001 / ISMS as taught in the professor deck

The class deck presents an ISMS through the Plan-Do-Check-Act (PDCA) logic and groups its control concerns into the following 11 areas. Use the class terminology when referencing what was taught; contemporary ISO editions may organise controls differently.

PDCA	Exam application
PLAN	Define scope, risk assessment, policies, objectives and control plan.
DO	Implement and operate security controls, responsibilities and training.
CHECK	Monitor, audit, review incidents/metrics and evaluate control effectiveness.
ACT	Correct deficiencies and continuously improve the ISMS.

Professor-deck concern areas: Security Policy; Organisation of Information Security; Asset Management; Human Resource Security; Physical & Environmental Security; Communications & Operations Management; Access Control; Information Systems Acquisition/Development/Maintenance; Information Security Incident Management; Business Continuity Management; Compliance.

Class source: Info-Security-ISO-27000-for-session-10.ppt.

6.4 NIST CSF 2.0 - current external quick reference

EXTERNAL 2026: NIST CSF 2.0 structures cyber-risk management as GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND and RECOVER. Use it to organise recommendations. SEARCH: [site:nist.gov "Cybersecurity Framework 2.0"](https://www.nist.gov/cybersecurity-framework/2.0) [issue]; incident response: [site:csrc.nist.gov "SP 800-61 Rev. 3"](https://www.csrc.nist.gov/sp-800-61-rev-3).

7. Identity & Access Management (IAM) - Credentials, Privileges, Dormant Accounts

7.1 The class IAM stack

Capability	Class focus	Case use
Identity Governance & Administration (IGA)	Automated lifecycle; role design; access request/approval; access review/certification; segregation of duties; self-service.	Dormant/orphaned accounts; excessive access; slow manual joiner/mover/leaver process.
Privileged Access Management (PAM)	Protect privileged credentials; accountability/traceability; temporary elevation; log privileged use.	Admin account abuse, service accounts, powerful shared credentials.
Access Management	SSO, authentication, federation, MFA, access policy and contextual access.	Stolen passwords, remote access, partner/federated access.
Customer IAM (CIAM)	Customer identity lifecycle, identity proofing/KYC, consent and preference management.	Customer portals, financial services, privacy and frictionless access.

Class source: Session 03 - Identity Mgmt-session-11.pptx.

7.2 If the case says "weak password"

- Do not stop at password complexity. Ask whether MFA existed, whether credentials were reused, whether SSO reduced password sprawl, and whether monitoring detected unusual login context.
- For remote/privileged access, argue for stronger authentication plus conditional/contextual access where appropriate.
- Check for dormant accounts: access should be removed on role change/exit and reviewed periodically.
- Apply least privilege and role-based access so compromise of one account does not imply unrestricted reach.
- For privileged users, use PAM, session logging and temporary elevation instead of standing administrator rights.

CASE LINK: CASE PRECEDENT - COLONIAL PIPELINE

The case identifies a legacy VPN account that was no longer actively used but had not been deactivated; its password appeared in a leaked-password batch, and the VPN account did not require MFA. This is a textbook link between identity lifecycle, credential hygiene and remote-access security.

8. Network Security - Firewalls, VPN, Segmentation and Remote Access

8.1 Firewall

A firewall enforces traffic rules at a network boundary. In an answer, state the policy objective: reduce unauthorised connectivity, restrict exposed services and segment trust zones. A firewall is not a substitute for secure endpoints, identity controls or application security.

8.2 VPN

A VPN protects communication over an untrusted network by creating an encrypted tunnel to a trusted endpoint. The key exam nuance: an encrypted VPN does not make a compromised identity trustworthy. Remote access still needs MFA, device/security posture controls, least privilege and monitoring.

8.3 Hotel/public Wi-Fi case lens

Risk	What to write	Controls
Untrusted local network	Users do not control other devices or access-point configuration.	Prefer trusted/mobile connection for sensitive tasks; use secure VPN; keep software updated; disable unnecessary sharing.
Rogue/evil-twin access point	Attacker may imitate a legitimate SSID.	Verify network, avoid auto-join, HTTPS/VPN, MFA.
Credential/session compromise	Weak application/session security can expose account access.	MFA, secure protocols, session controls, logout/revoke on suspicion.
Sensitive conversation exposure	Classified/highly sensitive calls require more than consumer convenience.	Use approved secure communication channels and organisational policy; location/context matters.

PYQ link: AY 2025-26 Q1 asked about web-based conference calls, hotel Wi-Fi, public safeguards and SIM cloning.

8.4 Segmentation

Segmentation limits lateral movement and blast radius. For a flat network, argue for separate zones by sensitivity/function, tighter access between zones and special separation of OT/critical systems. Pair network segmentation with identity-based access and monitoring.

9. Application Security and Secure SDLC

9.1 Security must start before penetration testing

The professor deck places security across Planning/Requirements, Design & Architecture, Development, QA & Testing, Production and Maintenance. The exam implication: "test at the end" is not a complete strategy.

SDLC stage	Security activity
Requirements	Security goals, data classification, regulatory requirements, abuse cases and risk assessment.
Design / architecture	Threat modelling, attack-surface reduction, trust boundaries, secure patterns and design review.
Development	Secure coding standards, code review, dependency/secret management, static analysis.
QA / testing	Dynamic testing, vulnerability scanning, penetration testing, security test cases.
Production	Secure configuration, monitoring, change/release control and least privilege.
Maintenance	Periodic assessment, patch/dependency management, logging review and retirement planning.

Class source: 20240721- Application Security-session-13.pptx.

9.2 Secure design principles from the class deck

Minimise attack surface; establish secure defaults; run with least privilege; defence in depth; fail securely; do not trust user/service input; separation of duties; avoid security by obscurity; keep security simple; fix root causes rather than symptoms.

9.3 OWASP - professor version vs current external version

The application-security deck uses the OWASP Top 10 list that includes Broken Access Control, Cryptographic Failures, Injection, Insecure Design, Security Misconfiguration, Vulnerable and Outdated Components, Identification & Authentication Failures, Software & Data Integrity Failures, Security Logging & Monitoring Failures, and SSRF. If the exam asks for the "latest OWASP Top 10," verify the current OWASP site during the exam: OWASP now publishes a 2025 list, which differs from the class deck.

SEARCH: GOOGLE THIS

site:owasp.org "OWASP Top 10" [vulnerability] or site:cheatsheetseries.owasp.org [control]. Use OWASP for application-security definitions and mitigation patterns.

10. Vulnerability, Patch Management and VAPT - A Repeated PYQ Theme

10.1 Why outdated software is dangerous

- Known weaknesses may be publicly documented and weaponised; unsupported systems may no longer receive security fixes.
- Attackers can automate scanning for vulnerable versions, making exposure scale quickly.
- Legacy dependencies and insecure configurations may accumulate, while compatibility concerns discourage updates.
- Missing patches transform a known, manageable weakness into avoidable residual risk.
- Patching alone is not enough: asset inventory, prioritisation, testing, change control and verification are required.

10.2 Vulnerability Assessment vs Penetration Testing

Dimension	Vulnerability Assessment	Penetration Test
Goal	Identify, quantify and prioritise weaknesses.	Demonstrate exploitability and potential impact.
Typical style	Broad, tool-heavy, often non-intrusive.	Narrower, expert-driven, may use exploits and be intrusive.
Output	Vulnerability findings/priorities.	Validated attack paths, evidence and impact.
Role	Starting point and recurring hygiene.	Deeper assurance at defined scope/point in time.

The VAPT deck also distinguishes Red Team Operations as a broader, realistic adversary simulation using OSINT and customised techniques, with the objective of testing detection and response as well as technical weaknesses.

Class source: 20240721 - Vulnerability Assessment Penetration Testing-session-13.pptx.

10.3 A high-impact patch/vulnerability programme

Inventory -> discover vulnerabilities -> assess exploitability/exposure/business criticality -> prioritise -> remediate/patch or apply compensating control -> test -> verify closure -> continuously monitor -> report metrics to risk owners.

RESEARCH: EXTERNAL 2026

CISA maintains a Known Exploited Vulnerabilities (KEV) Catalog as an authoritative source of vulnerabilities exploited in the wild and recommends using it as an input to vulnerability prioritisation. Search: [site:cisa.gov](https://www.cisa.gov/known-exploited-vulnerabilities-catalog) "Known Exploited Vulnerabilities" [CVE/product].

PYQ: PYQ PRECEDENT

AY 2024-25 Q1 explicitly centred on outdated software, weak passwords and insufficient employee training. AY 2025-26 Q2 again centred on outdated Windows systems and missing security patches in the WannaCry scenario. Treat asset/patch/vulnerability management as a priority theme.

11. Asset Lifecycle and Hardware Management - The "Printer" Lesson

Security starts with knowing what exists. The ISO deck emphasises asset inventory, ownership, acceptable use, classification, labelling and handling. The course outline explicitly includes cyber risk across the entire asset lifecycle.

Asset lifecycle answer

Stage	Questions to ask	Controls
Acquire / onboard	Is it approved? What data/process depends on it?	Security requirements, approved configuration, owner, inventory record.
Classify	How critical/sensitive is it?	Business value and CIA classification; retention and regulatory requirements.
Configure / deploy	Is the default setup secure?	Hardening, least functionality, credentials, segmentation, secure baseline.
Operate / monitor	Is it behaving as expected?	Logs, monitoring, access review, backup and configuration management.
Maintain	Is it patched/supported?	Vulnerability/patch management, capacity, change management, service review.
Retire / dispose	Can data or credentials remain?	Revoke access, remove from inventory, secure wipe/disposal, records update.

Why a printer can matter

A hardware device may be part of a critical control workflow, generate evidence, expose an unmanaged network path, contain stored data/credentials, or fail silently. The AY 2024-25 Bangladesh Bank question specifically asks students to highlight hardware management "like a printer" - signalling that asset management must include non-obvious devices, not just servers and software.

Class/PYQ sources: Info-Security-ISO-27000-for-session-10.ppt; course Session 14; AY 2024-25 Q2.

12. Malware, Ransomware and Operational Resilience

12.1 Ransomware attack chain

Initial access (phishing/stolen credentials/exposed service) -> privilege/foothold -> discovery and lateral movement -> data exfiltration (often) -> encryption/disruption -> extortion -> response/recovery.

12.2 What to analyse

Question	Answer lens
How did they get in?	Credential theft, phishing, exploitable vulnerability, remote access, supplier access.
Why did one foothold become enterprise impact?	Excessive privilege, flat network, weak segmentation, poor monitoring, shared credentials.
Why was downtime severe?	Critical dependencies, inadequate isolation, untested recovery, backups reachable by attacker, unclear BCP.
Was ransom the only impact?	No: data theft, operational loss, customer harm, regulatory/reputational consequences, societal disruption.
What controls matter most?	MFA, patching, segmentation, EDR/logging, least privilege, offline/isolated backups, tested restoration and incident playbooks.

12.3 Colonial Pipeline - a class precedent

- The HBS case identifies initial access through a legacy VPN account that was no longer actively used but had not been deactivated.
- The account password appeared among leaked passwords, and the VPN account did not require MFA.
- The event caused a multi-day shutdown and wider economic/public disruption, illustrating how IT compromise can create critical-infrastructure consequences.
- The case covers containment, ransom/payment considerations, crisis communication, government response, recovery and post-attack regulation.

Class source: HBS case Ransomware Attack at Colonial Pipeline Company.

RESEARCH: EXTERNAL 2026

CISA/MS-ISAC ransomware guidance emphasises offline/encrypted backups and regular restore testing. Search: [site:cisa.gov](https://www.cisa.gov) "Ransomware Guide" + [your sector].

13. Software Supply Chain and Third-Party Risk - SolarWinds Lens

13.1 Why supply-chain attacks are different

The attacker compromises a trusted supplier, software build/update mechanism or dependency so that the victim receives malicious content through an otherwise trusted relationship. Traditional perimeter trust can therefore work against the defender.

13.2 SolarWinds / SUNBURST class lessons

- The case describes malicious SUNBURST code inserted into Orion software updates, creating a trusted-update supply-chain compromise.
- SolarWinds rapidly involved external legal counsel and specialist investigators; leadership formed a tiger team/war-room response and used a separate encrypted communication channel because compromised systems might be monitored.
- The case emphasises uncertainty: customers wanted answers before SolarWinds could fully determine who was affected and how.
- Communication and disclosure are treated as strategic cyber-response decisions, not merely PR tasks.
- The case moves toward "Secure by Design" after the incident, highlighting build-system, product-security and organisational improvements.

13.3 Supplier and software-integrity controls

Before	During	After
Supplier due diligence; contract/security requirements; dependency inventory/SBOM; code signing and build integrity; least supplier access.	Verify updates; monitor anomalous behaviour; segregate management systems; preserve logs; validate vendor advisories.	Revoke compromised trust/signing material; rebuild from trusted sources; supplier review; improve SCRM and assurance.

FACULTY SIGNAL: CLASS DISCUSSION SIGNAL

The exam email thread contains SolarWinds discussion questions on whether the company could have prepared better, timing/content of the first 8-K, limited press engagement, stock-price impact and whether post-incident actions were sufficient. This strongly signals that incident response, disclosure and stakeholder management are examinable management dimensions.

Class sources: HBS SolarWinds Confronts SUNBURST; Exam Instructions.eml thread.

14. Detection, IDPS, Logs and Security Assurance

14.1 IDPS logic

An Intrusion Detection and Prevention System is useful because prevention can fail. In an exam, connect detection to the attack path: what observable behaviour should have raised an alert, and how quickly could the organisation act?

14.2 What good monitoring looks like

- Centralise relevant logs and protect log integrity; ensure clocks are synchronised so events can be reconstructed.
- Create actionable alert rules for authentication anomalies, privilege use, malware behaviour, unusual data movement and critical configuration changes.
- Use endpoint/network telemetry together; one source rarely tells the full story.
- Define escalation and ownership so alerts become decisions, not noise.
- Measure time to detect, time to contain, recurrence, patch latency and access-review exceptions.

14.3 Security assurance ladder

Vulnerability scan -> targeted penetration test -> broader red-team/adversary simulation -> audit/independent assurance -> management dashboard and continuous improvement.

Class sources: security governance deck; VAPT deck; ISO deck (monitoring, audit logging, incident management).

15. Critical Infrastructure and OT/ICS Security

15.1 Why Industry 4.0 changes risk

The critical-infrastructure deck describes increasing interconnection between operational technology (OT), industrial systems, IIoT sensors and cloud services. As IT/OT boundaries become more porous, attack paths expand while operational systems may be difficult to patch without affecting stability or safety.

15.2 Challenges from the class deck

Challenge	Exam implication
Awareness	Leadership/operators may under-estimate cyber risk because operational stability historically dominated security.
Visibility	Incomplete OT asset inventory creates blind spots and makes vulnerability/incident response harder.
Maintenance	SCADA/ICS may be legacy, unsupported or unable to accept patches easily.
Segmentation	Poor separation allows compromise to cross IT/OT boundaries.
Incident response	Cyber response must account for operational safety and continuity, not just reimage machines.
Governance	Security, engineering, operations, safety and vendors require shared decision rights.

Class frameworks named: ISA/IEC 62443, NIST Cybersecurity Framework, NERC CIP and ES-C2M2. Use only the one relevant to the question; do not framework-dump.

Class source: 20240715-Building Cyber Security into Critical Infrastructure-for-session-13.pptx.

CASE PRECEDENT: CASE LINK

Colonial Pipeline converts a cyber event into a physical-world/economic disruption. Use it when a question asks why cyber resilience is a business/societal imperative for critical infrastructure.

16. Data Privacy, Customer Data and Privacy by Design

16.1 Privacy is not the same as security

The LinkedIn case distinguishes privacy (appropriate control, use and consent around personal data) from security (technical/procedural safeguards against unauthorised access, alteration or destruction). A system can be secure from hackers yet still use personal data in a way that creates privacy risk.

16.2 LinkedIn case: high-value concepts

- Privacy by Design (PbD): privacy should be embedded into product design rather than bolted on after development.
- Differential privacy: LinkedIn explored adding calibrated noise to aggregate query results so useful insights could be provided while reducing the ability to infer an individual's data.
- Differencing attacks show that multiple seemingly safe aggregate queries can be combined to infer individual information.
- A privacy budget constrains repeated queries because privacy risk can accumulate; the product team had to balance privacy level, accuracy and business utility.
- Privacy teams worked with product, analytics, security and legal stakeholders - an example of privacy governance integrated into product development.

Class source: HBS Data Privacy in Practice at LinkedIn.

16.3 WEF/Oliver Wyman customer-data solution assessment

The Session 14 deck evaluates solutions on CYBER-RISK IMPACT (likelihood reduction, severity reduction, link to innovation-driven risk, uniqueness) and SOLUTION FEASIBILITY (design/implementation, cost-benefit, applicability and pace of innovation). This is a strong decision matrix when the question asks you to evaluate competing controls.

Class source: 20240720-World Economic Forum Cyber Risk to Customer Data-session-14.pptx.

16.4 India privacy research

EXTERNAL 2026: for an India/customer-data case, search the official MeitY pages for the Digital Personal Data Protection Act, 2023 and Digital Personal Data Protection Rules, 2025. Implementation is phased, so verify the provision/effective date relevant to the exam date rather than assuming every rule is already in force.

SEARCH: GOOGLE THIS

site:meity.gov.in "Digital Personal Data Protection" + [breach / security safeguards / notice / consent]. For banking, add site:rbi.org.in cyber security framework banks.

17. Incident Response, Disclosure, Crisis Communication and Recovery

17.1 Incident response is an enterprise process

Technical containment, legal privilege, regulatory reporting, customer support, operations, public communication and board decisions may all run simultaneously. SolarWinds and Colonial both show why senior leadership coordination matters.

17.2 Decision sequence

Decision	Questions
Validate	What is known? What is still uncertain? What evidence must be preserved?
Contain	Which accounts, systems, network segments or supplier trust paths must be isolated/revoked?
Eradicate	What root cause/backdoor/malware/credential must be removed?
Recover	Which services are priority? Are backups/builds trusted? How will recovery be tested?
Communicate	Who must know now - board, customers, employees, regulators, law enforcement, insurers, media?
Learn	What control/process/governance changes prevent recurrence, and how will effectiveness be measured?

17.3 Disclosure under uncertainty

A strong answer weighs speed against accuracy. Early disclosure may satisfy legal/market obligations and protect customers, but premature statements can be incomplete or misleading. Delay may improve accuracy but worsen customer harm, trust and regulatory exposure. State what is known, what is being investigated, what customers should do, and commit to updates.

17.4 Current external incident-response reference

EXTERNAL 2026: NIST SP 800-61 Rev. 3 (2025) integrates incident response into broader cybersecurity risk management and the NIST CSF 2.0. Use it when you need an authoritative modern source for preparation, detection, response and recovery.

EXTERNAL 2026 - India: CERT-In Directions under Section 70B require specified reportable cyber incidents to be reported within 6 hours of noticing them or being brought to notice; if not all information is available, the FAQ states entities may initially provide what is available and supplement later. Verify applicability to the scenario.

SEARCH: GOOGLE THIS

site:cert-in.org.in "Cyber Security Directions" reporting 6 hours; site:csrc.nist.gov "SP 800-61 Rev. 3"; [company] official incident update; site:sec.gov [company] cyber incident 8-K (for relevant US public companies).

18. Legal, Regulatory and Ethical Lens

Use this section selectively. The course outline expects organisational liability, the need for counsel, relevant laws, ethics, customer privacy and balancing business necessities with national security.

18.1 Regulatory source hierarchy

Scenario	First place to Google
India cyber incident	CERT-In official Directions/advisories; sector regulator if applicable.
Indian bank/financial institution	RBI cybersecurity/IT governance circulars + CERT-In.
Indian personal-data issue	MeitY DPDP Act/Rules official material; check effective dates.
US listed-company disclosure	SEC filing/company Investor Relations; then reputable reporting.
Critical infrastructure	Relevant government agency/CISA/NIST sector guidance.
Application weakness	OWASP/NIST/NVD/CISA rather than generic blogs.

18.2 Ethical tests that add value

- Necessity: is the security intervention genuinely needed for the stated risk?
- Proportionality: is the intrusion into privacy/freedom proportionate to the threat?
- Least intrusive alternative: can the objective be achieved with less privacy or autonomy cost?
- Transparency/accountability: who can challenge or oversee the decision?
- Consistency: is the company applying the same stated values across markets and stakeholder groups?

19. AI and Emerging Cybersecurity Trends

19.1 Three trends in the professor deck

- Growing on-demand access to ubiquitous data/information platforms.
- Attackers using AI, machine learning and other technology to launch increasingly sophisticated attacks.
- An expanding regulatory landscape plus gaps in cybersecurity resources, knowledge and talent.

19.2 Responses taught in class

Trend / capability	Exam use
Zero Trust Architecture	Shift trust decisions from a static perimeter to users, assets and resources; enforce granular policy and validate continuously.
Behaviour analytics	Identify anomalous user/device activity from access requests and device health/context.
Elastic log monitoring	Pull large log datasets into a central location for search, analysis and visualisation.
Homomorphic encryption	Enable certain computations on encrypted data without first decrypting it; useful as a privacy-enhancing concept.
Automation	Automate lower-risk routine actions (e.g., patching on lower-risk assets) so specialists focus on high-risk decisions.
Defensive AI/ML	Detect/remediate non-compliant systems, optimise workflows and analyse anomalies.
SSDLC / cloud / infrastructure codification / SBOM	Embed security in technology delivery and improve visibility into software components/dependencies.

Class source: 20240714-Cyber-Security-Trends-for-session-13.pptx.

19.3 If the question asks "How is AI influencing cybersecurity?"

Structure the answer on BOTH sides: ATTACKER ENABLEMENT (phishing/deepfakes, reconnaissance, content generation, automation, evasion) and DEFENDER ENABLEMENT (anomaly detection, triage, malware/phishing detection, prioritisation, automated response). Then add governance risks: false positives/negatives, data quality, model abuse, privacy, human oversight and attacker adaptation.

PYQ link: AY 2025-26 Q1 explicitly asked for scenarios in which AI is influencing cybersecurity.

20. Geopolitics, Viral Platforms and Privacy vs Safety

20.1 TikTok: why a consumer app becomes a national-security case

- The case centres on a recommendation-driven entertainment platform whose algorithm learns rapidly from user behaviour and can shape what users see.
- Concerns extend beyond ordinary privacy to potential foreign access to user data, location/behavioural insight, censorship/propaganda and influence over attention/information.
- The case also presents counterarguments: many data-collection concerns apply to other platforms and data brokers; regulation can raise free-expression and competition concerns.
- The analytical question is therefore governance of data and influence under geopolitical mistrust, not simply "TikTok is dangerous."

Class source: HBS TikTok: The Algorithm Will See You Now; course Session 6 learning outcomes include threat to democracy and geopolitical implications.

20.2 Apple: privacy vs public safety

- Strong encryption protects customers against criminals, espionage and data theft, but can limit law-enforcement access to device content.
- The case places Apple between customer privacy/security commitments, public-safety/national-security demands, legal obligations, market access and consistency across countries.
- A powerful answer avoids absolutes. Evaluate backdoor/key-access proposals for systemic security risk, necessity, proportionality, precedent, abuse potential and stakeholder trust.

Class source: HBS Apple: Privacy vs. Safety (A); course Session 18.

21. Case Precedent Library - Use These as Evidence, Not as Rote Answers

Case	Core lesson	Where it strengthens an unseen answer
Fortinet	Cybersecurity as a business ecosystem; fragmented point tools vs integrated platforms; hardware/ASIC and R&D strength; cloud narrative; marketing/M&A dilemma.	Use for security architecture integration, vendor landscape, innovation, build-vs-buy and business value of cybersecurity.
TikTok	Algorithmic recommendation, rapid preference inference, user-data and influence concerns, foreign-government/geopolitical risk, regulatory responses and free-speech trade-offs.	Use for platform risk, data sovereignty, algorithmic influence, national security, governance and proportionality.
LinkedIn	Privacy vs security distinction; Privacy by Design; differential privacy, differencing attack, privacy budget; utility-privacy trade-off.	Use for customer data, privacy engineering, analytics/API design and trust.
SolarWinds	Trusted software update/supply-chain compromise; legal counsel/tiger team; customer uncertainty; 8-K/media decisions; Secure by Design.	Use for supply-chain risk, disclosure, crisis communication, stakeholder management and post-incident transformation.
Colonial Pipeline	Legacy VPN account; undevisioned identity; leaked password possibility; no MFA; ransomware; shutdown and societal impact; crisis response.	Use for IAM, remote access, ransomware, critical infrastructure, business continuity and government response.
Apple	Encryption and privacy vs law enforcement/public safety; global legal/political consistency; customer trust.	Use for encryption, ethics, privacy, law, stakeholder trade-offs and national security.

EXAM MOVE: HOW TO CITE A CLASS CASE

One or two sentences are enough: "The Colonial Pipeline case illustrates how an undevisioned legacy VPN account without MFA can turn identity-governance weakness into critical-infrastructure disruption." Then return to the unseen case.

22. Reverse-Engineering the Two Prior Final Papers

22.1 AY 2024-25

Question	Signals	Best route through this playbook
Q1 Dakshin Bank breach	Sensitive customer data; unauthorised transactions; outdated software; weak password policy; lack of training; prevention.	Diagnostic -> Vulnerability/Patch -> IAM -> Privacy/Impact -> Controls/Governance.
Q2 Bangladesh Bank	Malware; banking-process vulnerabilities; funds diverted; importance of hardware such as a printer; how to stop attack.	Diagnostic -> Asset Lifecycle -> Monitoring -> Malware/Controls -> Governance/BCP.

22.2 AY 2025-26

Question	Signals	Best route through this playbook
Q1 German Air Force Webex leak	Web conferencing; hotel Wi-Fi; ordinary user protection; SIM cloning; AI influence.	Network/Remote Access -> IAM -> user controls -> evaluate causality -> AI trends -> national-security impact.
Q2 WannaCry / financial systems	Ransomware; outdated Windows; missing patches; encryption; interconnected financial systems; ATM/transaction disruption; solutions.	Vulnerability/Patch -> Ransomware -> Segmentation/Network -> BCP/Recovery -> Governance.

22.3 What repeats across both years

- Both years are two compulsory 20-mark questions and reward applied analysis rather than isolated definitions.
- Questions ask for diagnosis AND what management should have done.
- Legacy/outdated technology, weak control maintenance and asset management recur.
- Identity/human behaviour recur through weak passwords, training, remote-access/user practices.
- Operational/business consequences matter as much as the technical event.
- The examiner can introduce a real incident not directly taught as an HBS case, so frameworks must transfer to unseen cases.

PYQ PATTERN: PREDICTION RULE - NOT A PREDICTED QUESTION

Do not bet on a specific incident. Bet on the recurring skill: identify mistakes, explain why controls failed, and propose a prioritised security programme linked to business impact. That is exactly what current CLO 2 + CLO 3 reward.

23. Google Research Playbook - Exact Search Strings

The exam email explicitly expects Internet research. The goal is not to browse widely; it is to acquire a small set of high-authority evidence quickly.

23.1 The 3-source rule

Source role	What you need	Preferred source type
1. Incident facts	Timeline, scope, business impact, official response.	Company/regulator filing or official statement; Reuters/AP/BBC/FT-type reporting for independent chronology.
2. Technical facts	Initial access, malware/CVE, attack technique, mitigation.	CISA/FBI/NIST/NVD/MITRE/OWASP; reputable incident-response firm where directly involved.
3. Framework/legal/business	What good practice or obligation should look like.	NIST, CERT-In, MeitY, RBI/sector regulator, SEC/company filing, ISO class material.

23.2 First 8 minutes - copy these patterns into the Chrome address bar

Need	Google query template
Real named incident	"[Company/Incident]" cyberattack official statement root cause
Independent timeline	site:reuters.com "[Company/Incident]" cyberattack
US listed company	site:sec.gov "[Company]" cyber incident 8-K
Government advisory	site:cisa.gov "[malware/incident/product]" advisory mitigation
Threat actor behaviour	site:attack.mitre.org "[threat actor/malware]"
Vulnerability/CVE	"[CVE-number]" NVD CISA known exploited
Web/app flaw	site:owasp.org "[vulnerability name]"
Framework	site:nist.gov "Cybersecurity Framework 2.0" "[topic]"
Incident response	site:csrc.nist.gov "SP 800-61 Rev. 3"
India incident reporting	site:cert-in.org.in "Cyber Security Directions" [incident type]
India privacy	site:meity.gov.in "Digital Personal Data Protection" [issue]
Indian banking	site:rbi.org.in "Cyber Security Framework in Banks" [issue]
Hypothetical case	"[technology weakness]" cybersecurity best practices NIST CISA
Business impact	"[Company/Incident]" operations outage financial impact Reuters

23.3 What NOT to spend time on

- Do not open ten sources that repeat the same fact. Stop when you have authoritative support for the points you need.
- Do not search "full answer to [exam question]". Search the incident, weakness, framework and regulation separately; then synthesise.
- Do not rely on an SEO blog for a definition that NIST/CISA/OWASP/MITRE or a regulator publishes directly.
- Do not force a real-world fact into a hypothetical case. If you are making an assumption, label it clearly - the older exam instructions explicitly allow suitable logical assumptions if stated.

24. Evidence and Citation Kit

24.1 Basic in-text citation formats

Use simple, consistent citations unless your faculty specifies another style. Examples: (NIST, 2024); (CISA, accessed 2026); (CERT-In, 2022); (Company 8-K, 2026); (Reuters, 10 Sep 2026).

24.2 Reference-list mini template

NIST. (2024). The NIST Cybersecurity Framework (CSF) 2.0. National Institute of Standards and Technology.

CISA. (Year). [Title of advisory/guide]. Cybersecurity and Infrastructure Security Agency.

CERT-In. (2022). Directions under Section 70B of the Information Technology Act, 2000.

[Company]. (Date). [Official incident update / filing].

Reuters. (Date). [Article title].

24.3 Evidence table you can reproduce inside an answer

Evidence	Why it matters	Your inference
[Authoritative fact about entry vector]	Establishes immediate cause.	Control gap was [MFA/patch/config/etc.].
[Operational impact statistic]	Shows severity beyond technical compromise.	Availability/business continuity was material.
[Framework/regulatory requirement]	Provides benchmark for good practice.	Recommendation is anchored in recognised practice, not opinion.

EXAM MOVE: PARAPHRASE WITH PURPOSE

Do not rewrite a source sentence just to avoid copying. Extract the fact, cite it, then explain why that fact changes your diagnosis or recommendation.

25. Diagram and Table Kit - Fast Visuals That Earn Their Space

25.1 Attack-chain diagram

[Threat Actor] -> [Initial Access] -> [Exploit/Credential] -> [Privilege/Lateral Movement] -> [Target Asset] -> [CIA + Business Impact]

25.2 Root-cause fishbone substitute

PEOPLE	PROCESS	TECHNOLOGY	GOVERNANCE
Training / behaviour Insider / skills	Patching Deprovisioning Change/BCP	Legacy / config MFA/logging Segmentation	Ownership Risk appetite Metrics/assurance

25.3 NIST CSF 2.0 response diagram

GOVERN -> IDENTIFY -> PROTECT -> DETECT -> RESPOND -> RECOVER -> lessons/metrics feed back into GOVERN & IDENTIFY

25.4 Control roadmap table

Priority	Control	Owner	Why now	Metric
P0	Contain/revoke/isolate	Incident lead / IT	Stops active loss	Time to contain
P1	Close root cause	System/IAM owner	Prevents repeat entry	Remediation verified
P1	Detection/logging improvement	SOC/CISO	Reduces dwell time	MTTD / alert coverage
P1	Recovery validation	BCP/IT	Reduces outage impact	Restore test success / RTO
P2	Governance/architecture	CISO + business	Makes improvements sustainable	Risk/assurance dashboard

EXAM MOVE: VISUAL RULE

A useful diagram makes a claim visible. Label it and refer to it in the text: "Figure 1 shows that the organisation had multiple opportunities to break the attack chain before business-critical impact."

26. High-Impact Writing Bank

Diagnosis phrases

- "The breach was enabled by a control-maintenance failure rather than an unavoidable zero-day alone."
- "The immediate technical cause and the systemic organisational cause should be separated."
- "The weakness increased both likelihood of compromise and the eventual blast radius."
- "A trusted relationship became an attack path because trust was not continuously verified."
- "The incident reveals a gap between documented policy and operational control effectiveness."

Business-impact phrases

- "The cyber event became a business-continuity event once a digital dependency interrupted the organisation's ability to deliver its core service."
- "The impact extends beyond direct remediation cost to lost operations, customer trust, regulatory exposure and management attention."
- "For critical infrastructure, availability failure can propagate into societal and economic consequences."

Recommendation phrases

- "Controls should be prioritised by business criticality, exposure and evidence of active exploitation rather than by severity score alone."
- "The objective is defence in depth: failure of one control should not provide a direct path to the crown-jewel asset."
- "Management should pair technical remediation with an accountable operating process, owner, cadence and measurable assurance."
- "Where immediate patching is operationally unsafe, the organisation should use compensating controls, tighter segmentation, monitoring and a time-bound remediation plan."
- "Recovery capability should be demonstrated through testing, not inferred from the existence of backups or plans."

Conclusion template

"The key lesson is that cyber resilience depends less on a single product than on disciplined risk ownership across the asset lifecycle. The priority should be to remove the immediate attack path, limit blast radius through identity/segmentation controls, strengthen detection and recovery, and embed these controls in governance with measurable assurance."

27. Last 5-Minute Quality Check Before Submission

Check	What good looks like
Answered every command verb?	comment / elaborate / highlight / compare / recommend / assess are different tasks.
Used case facts, not only theory?	Every major section should tie back to the scenario.
Separated cause from impact?	Do not call the financial loss a vulnerability or the vulnerability an attack.
Covered CIA where relevant?	Test confidentiality, integrity AND availability.
Root causes multi-layered?	People + process + technology + governance.
Recommendations specific?	Each control states what, why, and preferably owner/timing/metric.
Prevent-Detect-Respond-Recover covered?	Not every case needs equal weight, but do not give prevention-only answers.
Framework used selectively?	NIST/ISO/IAM/SSDLC should structure analysis, not become a theory dump.
Business/legal/societal impact considered?	Use only what the case supports.
At least 2-4 credible citations?	Prefer official/primary + independent corroboration.
Visual labelled and referenced?	One useful diagram/table is better than decorative clutter.
Conclusion prioritises?	End with the 2-3 management actions that matter most.

28. Source Map - Exactly What This Playbook Was Built From

28.1 Current course architecture

MCRIA26 - CO (new PLOs).1.pdf - treated as the master syllabus. The current final exam is mapped to CLO 2 (20) and CLO 3 (20). Sessions span information-security foundations; regulation; cyber business; threats; TikTok; access/firewall/VPN; IDPS; privacy; governance/ISO; IAM; SolarWinds; app/critical-infrastructure security; asset management; Colonial Pipeline; implementation; legal/ethical issues; and Apple privacy vs safety.

28.2 Professor presentation pack

- CS26-1_kQ8Kk1bc6P.pdf - foundations, CIA, assets/threats/risk/vulnerabilities, business framing and threat taxonomy.
- 202506-Cyber-Security-Governance-for-session-10.pptx - six-step governance model, RASCI, holistic risk, programme and measurement.
- Info-Security-ISO-27000-for-session-10.ppt - CIA, ISMS/PDCA, class ISO control-area structure, access/incident/BCP/compliance.
- Session 03 - Identity Mgmt-session-11.pptx - IGA, PAM, access management, CIAM and business benefits.
- 20240721- Application Security-session-13.pptx - SSDLC, OWASP list taught in class, secure design and testing.
- 20240721 - Vulnerability Assessment Penetration Testing-session-13.pptx - VA vs pentest, red team, maturity and tools.
- 20240714-Cyber-Security-Trends-for-session-13.pptx - ZTA, behaviour analytics, log monitoring, homomorphic encryption, automation, defensive AI/ML, SSDLC/cloud/SBOM.
- 20240715-Building Cyber Security into Critical Infrastructure-for-session-13.pptx - IT/OT interconnection, threats/challenges and sector frameworks.
- 20240720-World Economic Forum Cyber Risk to Customer Data-session-14.pptx - innovation-driven cyber risk and impact/feasibility assessment criteria.

28.3 HBS cases supplied for the course

- Fortinet: Cybersecurity Pioneer Ken Xie Considers the Long Game.
- TikTok: The Algorithm Will See You Now.
- Data Privacy in Practice at LinkedIn.
- SolarWinds Confronts SUNBURST (A).
- Ransomware Attack at Colonial Pipeline Company.
- Apple: Privacy vs. Safety (A).

28.4 Prior final papers

CS24 - QP (Set 01).pdf - Dakshin Bank breach; Bangladesh Bank cyber-heist/hardware-management question.
CS25 - QP (Set 01).pdf - German Air Force Webex/hotel Wi-Fi/SIM cloning/AI question; WannaCry/financial-system question.

28.5 Exam instructions

Exam Instructions.eml - open-Internet expectation, trustworthy sources/basic citations, ~1000-word indicative limit, diagrams/visuals encouraged, mini research-report framing, and Chrome-address-bar Google-search workflow.

28.6 External 2026 quick-reference sources used only to make the research section current

Source	Use	Official page
NIST	The NIST Cybersecurity Framework (CSF) 2.0, 2024.	https://www.nist.gov/cyberframework
NIST	SP 800-61 Rev. 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management, 2025.	https://csrc.nist.gov/pubs/sp/800/61/r3/final
CISA	Known Exploited Vulnerabilities Catalog.	https://www.cisa.gov/known-exploited-vulnerabilities-catalog

Source	Use	Official page
CISA/MS-ISAC	Ransomware Guide.	https://www.cisa.gov/stopransomware
MITRE	MITRE ATT&CK Enterprise knowledge base.	https://attack.mitre.org/
OWASP	OWASP Top 10 / Cheat Sheet Series (current site; professor deck uses its taught list).	https://owasp.org/
CERT-In	Directions under Section 70B and FAQs on cyber-incident reporting.	https://www.cert-in.org.in/Directions70B.jsp
MeitY	Digital Personal Data Protection Act 2023 and Rules 2025 official material.	https://www.meity.gov.in/documents/act-and-policies
RBI	Cybersecurity/IT governance material for banking-sector scenarios.	https://www.rbi.org.in/

External facts in this playbook were checked against official pages in September 2026. During the exam, verify time-sensitive legal/regulatory details and incident facts before relying on them.

29. Rapid Glossary - Searchable Terms

Term	Exam-ready meaning
Attack surface	The set of reachable points through which a system/organisation can be attacked.
Backdoor	A method of bypassing normal access/security controls.
CIA triad	Confidentiality, Integrity, Availability.
Compensating control	Alternative control used when the preferred control cannot yet be implemented.
DDoS	Distributed Denial of Service - many sources overwhelm or disrupt a service.
Defence in depth	Multiple independent control layers so one failure is not catastrophic.
EDR	Endpoint Detection and Response - endpoint telemetry/detection/response capability.
Honeypot / honeynet	Decoy system/network designed to attract/observe attackers and generate detection intelligence.
IAM	Identity and Access Management.
IDPS	Intrusion Detection and Prevention System.
Least privilege	Grant only the minimum access needed for a task.
MFA	Multi-factor authentication - more than one independent factor for authentication.
PAM	Privileged Access Management.
RaaS	Ransomware as a Service - ransomware infrastructure/capability offered to affiliates.
RBAC	Role-Based Access Control.
Risk appetite	Amount/nature of risk an organisation is willing to accept.
SBOM	Software Bill of Materials - inventory of software components/dependencies.
SIEM	Security Information and Event Management - central collection/correlation/analysis of security logs/events.
SIM cloning	Creating/using a duplicate SIM identity to impersonate a mobile subscriber; distinguish it from other telecom/social-engineering attacks and verify mechanism before attributing an incident.
SSDLC	Secure Software Development Life Cycle.
Supply-chain attack	Compromise delivered through a trusted supplier, dependency, service or software update path.
Threat	Potential source/cause of harm.
Vulnerability	Weakness that a threat can exploit.
VPN	Virtual Private Network - encrypted tunnel over an untrusted network; does not replace identity/device security.
Zero Trust	Security approach that avoids implicit trust based only on network location and continuously validates access to resources.